

SecurityGroup101 — Vendor Risk Tiering Matrix

NIST SP 800-161 Rev. 1 Upd. 1 SR-9 Criticality Analysis · NIST SP 800-53 Rev. 5 SR-2, RA-9 · NIST CSF 2.0 GV.SC-06 · PCI DSS v4.0 Req 12.8.1 · GLBA Safeguards Rule §314.4(f)

July 2026 · Maxine Jones, GRC Analyst — mkj00015@mix.wvu.edu

PURPOSE: Assigns vendors to a risk tier based on data sensitivity, system access, and business impact. Tier assignment determines the depth of due diligence, assessment frequency, contract requirements, and ongoing monitoring intensity applied to each vendor. Per NIST SP 800-161 Rev. 1 Upd. 1 SR-9 (Criticality Analysis) and GLBA Safeguards Rule 16 CFR §314.4(f) (vendor oversight obligations).

Risk Tier	Data / Access Criteria	Regulatory Relevance	Assessment Required	Review Frequency	Contract Requirements
Tier 1 CRITICAL Examples: AWS, Stripe, Okta, Snowflake	Handles regulated data (PHI, PCI-scope PANs, PII at scale) OR has direct access to production systems OR has administrative/privileged access. A compromise could trigger regulatory breach, financial loss, or operational outage.	HIPAA BAA required (PHI). PCI DSS v4.0 Req 12.8 — written agreement, annual compliance confirmation (PCI-scope). GLBA Safeguards Rule §314.4(f) — all financial data vendors. FFIEC third-party cybersecurity guidance.	Full CAIQ v4 self-assessment (85 questions) OR current SOC 2 Type II report (within 12 months). Penetration test summary on request. Right-to-audit clause required in contract.	Annual. Out-of-cycle review triggered by: security incident, material change to service or ownership, KEV catalog findings affecting vendor software.	Breach notification ≤72 hrs (contractual). AES-256 at rest. TLS 1.2+ in transit. Audit rights. Subprocessor disclosure + 30-day change notice. Data return or certified deletion on termination.
Tier 2 HIGH Examples: Datadog, GitHub, Zendesk	Accesses or stores Confidential data (customer PII, financial records, proprietary business data) without meeting Tier 1 criteria. Significant business impact if compromised but lower regulatory exposure.	GLBA Safeguards Rule privacy and data handling obligations. State privacy laws (CCPA where applicable). Contractual confidentiality obligations.	Abbreviated 36-question Vendor Risk Scoring Rubric OR SOC 2 Type II summary (within 18 months). Security policy documentation review.	Bi-annual. Triggered review on material changes or security incidents.	Breach notification ≤72 hrs. Data handling restrictions. TLS 1.2+ in transit. Confidentiality clause. Basic security requirements. Data disposal on termination.
Tier 3 MODERATE Examples: DocuSign, Twilio, non-critical SaaS	Accesses or stores Internal data only (no regulated or confidential customer data). Limited or indirect business impact if compromised. No direct production system access.	General data handling and confidentiality obligations. Standard contractual terms.	Standard 10–15 question questionnaire OR publicly available Trust Center / SOC 2 summary review. No custom assessment required.	Annual documentation review.	Confidentiality clause. Basic data handling restrictions. Breach notification requirement (no contractual SLA mandate).
Tier 4 LOW Examples: Office catering, cleaning services, non-IT consultants	No access to SecurityGroup101 data, systems, or networks. Business impact limited to operational disruption only. Examples: physical facilities vendors, non-digital service providers.	Standard commercial contract obligations only. No cybersecurity regulatory requirements triggered.	No cybersecurity assessment required. Standard commercial background check and contract review.	Review only at contract renewal or scope change.	Standard commercial contract terms only. No specific security or data handling requirements.

